

Secure Website Project: Before and After Changes

Before Changes (Vulnerabilities)



1. **Input Validation Missing**:

- No sanitization of user inputs, allowing XSS injection.
- User could enter `

2. **XSS Vulnerability**:

- Inputs were directly echoed without escaping, allowing malicious JavaScript execution.

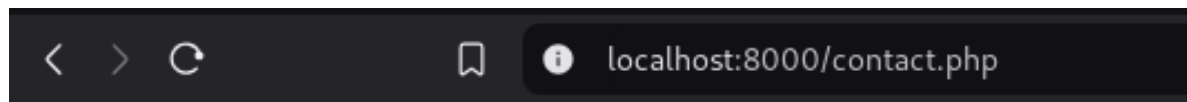
3. **No HTTPS Enforcement**:

- Data could be sent over an insecure HTTP connection, leading to Man-in-the-Middle (MITM) attacks.

4. **No Security Headers**:

- Missing Content Security Policy (CSP), XSS protection, and other security headers.

After Changes (Improvements)



Contact Form

Name:

Email:

Message:

1. **Input Validation Implemented**:

- Used `htmlspecialchars(strip_tags(trim($_POST['name'])))` to sanitize input.
- Applied `filter_var($_POST['email'], FILTER_VALIDATE_EMAIL)` to validate email format.

2. **XSS Prevention**:

- Added `htmlspecialchars()` to encode special characters and prevent script execution.
- Applied Content Security Policy (CSP) to block inline JavaScript.

3. **HTTPS Enforcement**:

- Configured `.htaccess` to redirect all traffic to HTTPS for secure data transmission.

4. **Security Headers Added**:

- `X-XSS-Protection: 1; mode=block`
- `X-Content-Type-Options: nosniff`
- `X-Frame-Options: DENY`
- `Content-Security-Policy: default-src 'self'; script-src 'self'; object-src 'none';`

Testing for XSS Vulnerability

1. ****Before Fixes:**** Entering ``<script>alert("XSS")</script>`` in the form fields triggered an alert.
2. ****After Fixes:**** The script is safely displayed as text and does not execute.